

Corrigé du TP : Déploiement de JEA (Just Enough Administration)

Préparation de l'environnement (Groupes et Répertoires)

Commandes exécutées :

- `New-ADGroup -Name "JEA_DNS_Admins" -GroupCategory Security -GroupScope Global`
- `Add-ADGroupMember -Identity "JEA_DNS_Admins" -Members "pirate"`
- `New-Item -Path "C:\JEA_Transcripts" -ItemType Directory`

Explication : L'architecture JEA repose sur les identités Active Directory existantes. L'utilisateur `pirate` reste un utilisateur standard du domaine sans aucun droit d'administration. Le répertoire créé servira de coffre-fort pour enregistrer toutes les actions effectuées via JEA, répondant ainsi aux exigences de traçabilité d'un SOC.

Création du fichier de Capacité de Rôle (.psrc)

Ligne modifiée dans le fichier `ManageDNS.psrc` :

- `VisibleCmdlets = @{{ Name = 'Restart-Service'; Parameters = @{{ Name = 'Name'; ValidateSet = 'dns' }}, @{{ Name = 'Get-Service'; Parameters = @{{ Name = 'Name'; ValidateSet = 'dns' }}}`

Explication : C'est la définition de la Liste Blanche (Whitelisting). Nous n'autorisons pas simplement la commande `Restart-Service`. Nous bridons ses paramètres (`ValidateSet = 'dns'`). Si le technicien tente d'exécuter `Restart-Service -Name spooler`, la commande sera rejetée par le moteur JEA, garantissant qu'il ne peut agir que sur son périmètre strict.

Création du fichier de Configuration de Session (.pssc)

Commande exécutée :

- `New-PSSessionConfigurationFile -Path "C:\JEA_Config.pssc" -SessionType RestrictedRemoteServer -RunAsVirtualAccount $true -TranscriptDirectory`

```
"C:\JEA_Transcripts" -RoleDefinitions @{ 'formation\JEA_DNS_Admins' = @{  
RoleCapabilities = 'ManageDNS' } }
```

Explication de l'architecture :

- **RestrictedRemoteServer** : Force la session PowerShell en mode contraint (Constrained Language Mode).
- **RunAsVirtualAccount \$true** : C'est le cœur de JEA (L'exécution par procuration). L'utilisateur **pirate** ne verra jamais ses propres droits élevés. JEA créera un compte Administrateur Local "Fantôme" le temps de la session pour exécuter les commandes à sa place, puis le détruira.
- **RoleDefinitions** : Effectue le pont (Mapping) entre le groupe Active Directory standard et les droits accordés dans le fichier **.psrc**.

Enregistrement du point de terminaison JEA

Commandes exécutées :

- Register-PSSessionConfiguration -Name "DNS_Maintenance" -Path "C:\JEA_Config.pssc" -Force
- Restart-Service WinRM

Explication : Cette étape publie la configuration JEA sur le service de gestion à distance de Windows (WinRM). Le service réseau écoute désormais sur un nouveau "guichet" d'administration nommé **DNS_Maintenance**.

Validation et tests d'exécution (Le Crash-Test)

Test de connexion :

- Enter-PSSession -ComputerName localhost -ConfigurationName "DNS_Maintenance" -Credential "formation\pirate"

Analyse des résultats :

1. **L'environnement bridé** : Si vous avez tapé **Get-Command**, vous avez pu constater que la quasi-totalité des commandes système ont disparu de la session.
2. **Le Langage Contraint (CLM)** : La tentative d'exécuter du code .NET (**New-Object System.IO.FileInfo**) a échoué. JEA empêche l'exécution de code arbitraire et de

malwares.

3. **Le fichier de Transcription :** En allant dans le dossier **C:\JEA_Transcripts** avec le compte Administrateur de la machine, vous avez trouvé un fichier texte. Ce fichier (Over-the-shoulder log) contient la retranscription exacte de toutes les commandes tapées, y compris les erreurs et les résultats affichés à l'écran de l'utilisateur **pirate**.

•